

Télécom SudParis

Cours sur les architectures sécurisées

Cyril Poirret

ANSSI

2026

Plan

1 Introduction

2 Principes généraux d'architecture sécurisée

3 Socle de connaissances

4 Étude de cas : passerelle d'interconnexion à Internet

5 Conclusion

Objectif de ce cours

Pour **comprendre les raisons et les conséquences des choix d'une architecture sécurisée de SI**, ce cours :

- constitue un bagage théorique des principes d'architecture sécurisée de SI ;

Objectif de ce cours

Pour **comprendre les raisons et les conséquences des choix d'une architecture sécurisée de SI**, ce cours :

- constitue un bagage théorique des principes d'architecture sécurisée de SI ;
- met en évidence un ensemble de recommandations de sécurité liées aux architectures de SI ;

Objectif de ce cours

Pour **comprendre les raisons et les conséquences des choix d'une architecture sécurisée de SI**, ce cours :

- constitue un bagage théorique des principes d'architecture sécurisée de SI ;
- met en évidence un ensemble de recommandations de sécurité liées aux architectures de SI ;
- présente le cas de l'architecture d'une passerelle d'interconnexion à Internet (guide ANSSI de référence : recommandations relatives à l'interconnexion d'un système d'information à Internet).

Plan du cours

1 Introduction

Plan du cours

1 Introduction
2 Principes généraux d'architecture sécurisée

Plan du cours

1 Introduction
2 Principes généraux d'architecture sécurisée
- Qu'est-ce qu'une architecture sécurisée ?

Plan du cours

1. Introduction
2. Principes généraux d'architecture sécurisée
   - Qu'est-ce qu'une architecture sécurisée ?
   - principes et modèles de sécurité des SI ;

Plan du cours

1. Introduction
2. Principes généraux d'architecture sécurisée
   - Qu'est-ce qu'une architecture sécurisée ?
   - principes et modèles de sécurité des SI ;
   - Exemple de modèles de sécurité formels

Plan du cours

1. Introduction
2. Principes généraux d'architecture sécurisée
   - Qu'est-ce qu'une architecture sécurisée ?
   - principes et modèles de sécurité des SI ;
   - Exemple de modèles de sécurité formels
3. Socle de connaissances

Plan du cours

1. Introduction
2. Principes généraux d'architecture sécurisée
   - Qu'est-ce qu'une architecture sécurisée ?
   - principes et modèles de sécurité des SI ;
   - Exemple de modèles de sécurité formels
3. Socle de connaissances
4. Étude de cas : passerelle d'interconnexion à Internet

Plan du cours

1. Introduction
2. Principes généraux d'architecture sécurisée
   - Qu'est-ce qu'une architecture sécurisée ?
   - principes et modèles de sécurité des SI ;
   - Exemple de modèles de sécurité formels
3. Socle de connaissances
4. Étude de cas : passerelle d'interconnexion à Internet
   - Expression de besoin ;

Plan du cours

1. Introduction
2. Principes généraux d'architecture sécurisée
   - Qu'est-ce qu'une architecture sécurisée ?
   - principes et modèles de sécurité des SI ;
   - Exemple de modèles de sécurité formels
3. Socle de connaissances
4. Étude de cas : passerelle d'interconnexion à Internet
   - Expression de besoin ;
   - Choix d'architecture ;

Plan du cours

1. Introduction
2. Principes généraux d'architecture sécurisée
   - Qu'est-ce qu'une architecture sécurisée ?
   - principes et modèles de sécurité des SI ;
   - Exemple de modèles de sécurité formels
3. Socle de connaissances
4. Étude de cas : passerelle d'interconnexion à Internet
   - Expression de besoin ;
   - Choix d'architecture ;
   - Navigation Web ;

Plan du cours

1. Introduction
2. Principes généraux d'architecture sécurisée
   - Qu'est-ce qu'une architecture sécurisée ?
   - principes et modèles de sécurité des SI ;
   - Exemple de modèles de sécurité formels
3. Socle de connaissances
4. Étude de cas : passerelle d'interconnexion à Internet
   - Expression de besoin ;
   - Choix d'architecture ;
   - Navigation Web ;
   - Messagerie électronique ;

Plan du cours

1. Introduction
2. Principes généraux d'architecture sécurisée
   - Qu'est-ce qu'une architecture sécurisée ?
   - principes et modèles de sécurité des SI ;
   - Exemple de modèles de sécurité formels
3. Socle de connaissances
4. Étude de cas : passerelle d'interconnexion à Internet
   - Expression de besoin ;
   - Choix d'architecture ;
   - Navigation Web ;
   - Messagerie électronique ;
   - Vision globale.

Plan

1 Introduction

2 Principes généraux d'architecture sécurisée

3 Socle de connaissances

4 Étude de cas : passerelle d'interconnexion à Internet

5 Conclusion

Plan

2 Principes généraux d'architecture sécurisée
- Qu'est-ce qu'une architecture sécurisée ?
- Principes et modèles de sécurité des SI
- Exemple de modèles de sécurité formels

Qu'est-ce que l'architecture sécurisée d'un SI ?



Architecture

Un ensemble de représentations physiques et logiques (i.e. des vues) d'un système ou d'une solution. L'architecture donne des informations sur les éléments constitutifs du système/solution, sur ses interconnexions, ses relations à d'autres systèmes et son fonctionnements selon différents niveaux d'abstraction et selon différents périmètres. *NIST SP 800-160v1*

Qu'est-ce que l'architecture sécurisée d'un SI ?



Architecture de sécurité de l'information

Un ensemble de représentations physiques et logiques (i.e. des vues) d'un système ou d'une solution qui donne des informations sur la façon dont le système se décompose en domaines de sécurité et l'utilisation d'éléments de sécurité pour implémenter les politiques de sécurité à l'intérieur et entre chaque domaine de sécurité, ainsi que la manière dont les données et les informations doivent être sécurisées. *NIST SP 800-160v1*

Une architecture sécurisée au regard de quoi ?

Une architecture sécurisée au regard de quoi ?

Avant de concevoir une architecture sécurisée, il est impératif de formaliser une analyse des risques :

- Identifier les sources de risques pertinentes ;

Une architecture sécurisée au regard de quoi ?

Avant de concevoir une architecture sécurisée, il est impératif de formaliser une analyse des risques :

- Identifier les sources de risques pertinentes ;
  - organisations étatiques ;

Une architecture sécurisée au regard de quoi ?

Avant de concevoir une architecture sécurisée, il est impératif de formaliser une analyse des risques :

- Identifier les sources de risques pertinentes ;
  - organisations étatiques ;
  - organisations cybercriminelles ;

Une architecture sécurisée au regard de quoi ?

Avant de concevoir une architecture sécurisée, il est impératif de formaliser une analyse des risques :

- Identifier les sources de risques pertinentes ;
  - organisations étatiques ;
  - organisations cybercriminelles ;
  - hacktivists ;

Une architecture sécurisée au regard de quoi ?

Avant de concevoir une architecture sécurisée, il est impératif de formaliser une analyse des risques :

- Identifier les sources de risques pertinentes ;
  - organisations étatiques ;
  - organisations cybercriminelles ;
  - hacktivists ;
- Identifier les objectifs visés pertinents ;

Une architecture sécurisée au regard de quoi ?

Avant de concevoir une architecture sécurisée, il est impératif de formaliser une analyse des risques :

- Identifier les sources de risques pertinentes ;
  - organisations étatiques ;
  - organisations cybercriminelles ;
  - hacktivists ;
- Identifier les objectifs visés pertinents ;
  - vol de secrets industriels ;

Une architecture sécurisée au regard de quoi ?

Avant de concevoir une architecture sécurisée, il est impératif de formaliser une analyse des risques :

- Identifier les sources de risques pertinentes ;
  - organisations étatiques ;
  - organisations cybercriminelles ;
  - hacktivists ;
- Identifier les objectifs visés pertinents ;
  - vol de secrets industriels ;
  - séquestration des données de production ;

Une architecture sécurisée au regard de quoi ?

Avant de concevoir une architecture sécurisée, il est impératif de formaliser une analyse des risques :

- Identifier les sources de risques pertinentes ;
  - organisations étatiques ;
  - organisations cybercriminelles ;
  - hacktivists ;
- Identifier les objectifs visés pertinents ;
  - vol de secrets industriels ;
  - séquestration des données de production ;
  - défiguration du site internet ;

Une architecture sécurisée au regard de quoi ?

Avant de concevoir une architecture sécurisée, il est impératif de formaliser une analyse des risques :

- Identifier les sources de risques pertinentes ;
  - organisations étatiques ;
  - organisations cybercriminelles ;
  - hacktivists ;
- Identifier les objectifs visés pertinents ;
  - vol de secrets industriels ;
  - séquestration des données de production ;
  - défiguration du site internet ;
- Identifier comment les sources de risques pourraient parvenir à réaliser leurs objectifs.

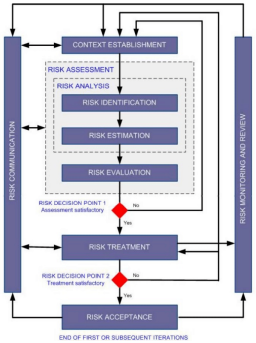
Une architecture sécurisée au regard de quoi ?

Avant de concevoir une architecture sécurisée, il est impératif de formaliser une analyse des risques :

- Identifier les sources de risques pertinentes ;
  - organisations étatiques ;
  - organisations cybercriminelles ;
  - hacktivists ;
- Identifier les objectifs visés pertinents ;
  - vol de secrets industriels ;
  - séquestration des données de production ;
  - défiguration du site internet ;
- Identifier comment les sources de risques pourraient parvenir à réaliser leurs objectifs.
- Quoi d'autre ?

Comment valider une architecture de sécurité ?

Comment valider une architecture de sécurité ?



The ISO 27005 Risk management framework

Homologation de sécurité et analyse des risques :

- ISO 27005 fournit un cadre, **qu'est ce que je dois faire** pour mettre en oeuvre un processus de gestion des risques ;

Comment valider une architecture de sécurité ?

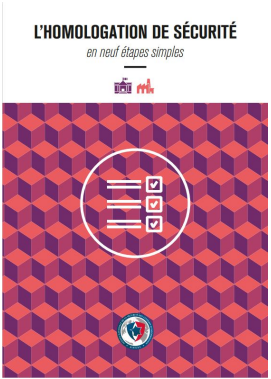


Homologation de sécurité et analyse des risques :

- ISO 27005 fournit un cadre, **qu'est ce que je dois faire** pour mettre en oeuvre un processus de gestion des risques ;
- Ebios-RM, fournit une méthode **comment je dois faire** pour réaliser des analyses des risques ;

EBIOS - Risk Manager
https ://www.ssi.gouv.fr/entreprise/management-du-risque/la-methode-ebios-risk-manager/

Comment valider une architecture de sécurité ?



Guide - Homologation de sécurité

Homologation de sécurité et analyse des risques :

- ISO 27005 fournit un cadre, **qu'est ce que je dois faire** pour mettre en oeuvre un processus de gestion des risques ;
- Ebios-RM, fournit une méthode **comment je dois faire** pour réaliser des analyses des risques ;
- L'homologation est à la fois un processus et une décision. La décision représente l'acceptation formelle des risques résiduels et valide l'architecture de sécurité tout en précisant les actions nécessaire pour son amélioration.

Lois et réglementations

Les architectures de sécurité peuvent être soumises à la réglementation :

- Réseaux classifiés et sensibles :

Lois et réglementations

Les architectures de sécurité peuvent être soumises à la réglementation :

- Réseaux classifiés et sensibles :
  - IGI 1300 : Instruction définissant les principes de la protection du secret de la défense nationale ;

Lois et réglementations

Les architectures de sécurité peuvent être soumises à la réglementation :

- Réseaux classifiés et sensibles :
  - IGI 1300 : Instruction définissant les principes de la protection du secret de la défense nationale ;
  - IGI 2100 / IGI 2102 : Instruction définissant les principes de protection des informations classifiées de l'OTAN et de l'UE ;

Lois et réglementations

Les architectures de sécurité peuvent être soumises à la réglementation :

- Réseaux classifiés et sensibles :
  - IGI 1300 : Instruction définissant les principes de la protection du secret de la défense nationale ;
  - IGI 2100 / IGI 2102 : Instruction définissant les principes de protection des informations classifiées de l'OTAN et de l'UE ;
  - II 300 : Instruction spécifique à la protection contre les signaux parasites compromettants ;

Lois et réglementations

Les architectures de sécurité peuvent être soumises à la réglementation :

- Réseaux classifiés et sensibles :
  - IGI 1300 : Instruction définissant les principes de la protection du secret de la défense nationale ;
  - IGI 2100 / IGI 2102 : Instruction définissant les principes de protection des informations classifiées de l'OTAN et de l'UE ;
  - II 300 : Instruction spécifique à la protection contre les signaux parasites compromettants ;
  - II 901 : Instruction spécifique à la protection des SI sensibles et de niveau "'Diffusion Restreinte"' ;

Lois et réglementations

Les architectures de sécurité peuvent être soumises à la réglementation :

- Réseaux classifiés et sensibles :
  - IGI 1300 : Instruction définissant les principes de la protection du secret de la défense nationale ;
  - IGI 2100 / IGI 2102 : Instruction définissant les principes de protection des informations classifiées de l'OTAN et de l'UE ;
  - II 300 : Instruction spécifique à la protection contre les signaux parasites compromettants ;
  - II 901 : Instruction spécifique à la protection des SI sensibles et de niveau "'Diffusion Restreinte"' ;
- Opérateurs réglementés

Lois et réglementations

Les architectures de sécurité peuvent être soumises à la réglementation :

- Réseaux classifiés et sensibles :
  - IGI 1300 : Instruction définissant les principes de la protection du secret de la défense nationale ;
  - IGI 2100 / IGI 2102 : Instruction définissant les principes de protection des informations classifiées de l'OTAN et de l'UE ;
  - II 300 : Instruction spécifique à la protection contre les signaux parasites compromettants ;
  - II 901 : Instruction spécifique à la protection des SI sensibles et de niveau "'Diffusion Restreinte"' ;
- Opérateurs réglementés
  - Opérateurs de Services Essentiels (OSE) : Directive européenne NIS (maintenant EI et EE avec NIS2)

Lois et réglementations

Les architectures de sécurité peuvent être soumises à la réglementation :

- Réseaux classifiés et sensibles :
  - IGI 1300 : Instruction définissant les principes de la protection du secret de la défense nationale ;
  - IGI 2100 / IGI 2102 : Instruction définissant les principes de protection des informations classifiées de l'OTAN et de l'UE ;
  - II 300 : Instruction spécifique à la protection contre les signaux parasites compromettants ;
  - II 901 : Instruction spécifique à la protection des SI sensibles et de niveau "'Diffusion Restreinte"' ;
- Opérateurs réglementés
  - Opérateurs de Services Essentiels (OSE) : Directive européenne NIS (maintenant EI et EE avec NIS2)
  - Opérateurs d'Importance Vitale (OIV) : Loi de Programmation Militaire (LPM)

Lois et réglementations

Les architectures de sécurité peuvent être soumises à la réglementation :

- Réseaux classifiés et sensibles :
  - IGI 1300 : Instruction définissant les principes de la protection du secret de la défense nationale ;
  - IGI 2100 / IGI 2102 : Instruction définissant les principes de protection des informations classifiées de l'OTAN et de l'UE ;
  - II 300 : Instruction spécifique à la protection contre les signaux parasites compromettants ;
  - II 901 : Instruction spécifique à la protection des SI sensibles et de niveau "'Diffusion Restreinte"' ;
- Opérateurs réglementés
  - Opérateurs de Services Essentiels (OSE) : Directive européenne NIS (maintenant EI et EE avec NIS2)
  - Opérateurs d'Importance Vitale (OIV) : Loi de Programmation Militaire (LPM)
- Administrations publiques : Référentiel Général de la Sécurité (RGS) ;

Lois et réglementations

Les architectures de sécurité peuvent être soumises à la réglementation :

- Réseaux classifiés et sensibles :
  - IGI 1300 : Instruction définissant les principes de la protection du secret de la défense nationale ;
  - IGI 2100 / IGI 2102 : Instruction définissant les principes de protection des informations classifiées de l'OTAN et de l'UE ;
  - II 300 : Instruction spécifique à la protection contre les signaux parasites compromettants ;
  - II 901 : Instruction spécifique à la protection des SI sensibles et de niveau "'Diffusion Restreinte"' ;
- Opérateurs réglementés
  - Opérateurs de Services Essentiels (OSE) : Directive européenne NIS (maintenant EI et EE avec NIS2)
  - Opérateurs d'Importance Vitale (OIV) : Loi de Programmation Militaire (LPM)
- Administrations publiques : Référentiel Général de la Sécurité (RGS) ;
- Secteur de la santé, secteur privé : Réglement Général sur la Protection des Données (RGPD).

Point sur les éléments de sécurité

Le soin apporté à la définition d'une architecture sécurisée doit être complété par :

- une **sélection réfléchie des composants individuels** en fonction de :

Point sur les éléments de sécurité

Le soin apporté à la définition d'une architecture sécurisée doit être complété par :

- une **sélection réfléchie des composants individuels** en fonction de :
  - leur apport du point de vue de leur sécurité,

Point sur les éléments de sécurité

Le soin apporté à la définition d'une architecture sécurisée doit être complété par :

- une **sélection réfléchie des composants individuels** en fonction de :
  - leur apport du point de vue de leur sécurité,
  - leur propre robustesse (p. ex. avec un visa de sécurité ANSSI) ;



Point sur les éléments de sécurité

Le soin apporté à la définition d'une architecture sécurisée doit être complété par :

- une **sélection réfléchie des composants individuels** en fonction de :
  - leur apport du point de vue de leur sécurité,
  - leur propre robustesse (p. ex. avec un visa de sécurité ANSSI) ;
- un **durcissement et une maîtrise de ces composants**, c'est-à-dire le temps nécessaire :

Point sur les éléments de sécurité

Le soin apporté à la définition d'une architecture sécurisée doit être complété par :

- une **sélection réfléchie des composants individuels** en fonction de :
  - leur apport du point de vue de leur sécurité,
  - leur propre robustesse (p. ex. avec un visa de sécurité ANSSI) ;
- un **durcissement et une maîtrise de ces composants**, c'est-à-dire le temps nécessaire :
  - à leur configuration sécurisée,

Point sur les éléments de sécurité

Le soin apporté à la définition d'une architecture sécurisée doit être complété par :

- une **sélection réfléchie des composants individuels** en fonction de :
  - leur apport du point de vue de leur sécurité,
  - leur propre robustesse (p. ex. avec un visa de sécurité ANSSI) ;
- un **durcissement et une maîtrise de ces composants**, c'est-à-dire le temps nécessaire :
  - à leur configuration sécurisée,
  - à la formation des administrateurs.

Comment choisir ses produits de sécurité ?

Les produits de sécurité sont parfois *certifiés, qualifiés ou agréés*, quelle différence ?



Comment choisir ses produits de sécurité ?

- Un produit **certifié** Critères Communs :



Comment choisir ses produits de sécurité ?



- Un produit **certifié** Critères Communs :
  - atteste qu'un évaluateur indépendant a vérifié que le produit possède les fonctions de sécurité définies par l'industriel dans la cible de sécurité ;

Comment choisir ses produits de sécurité ?



- Un produit **certifié** Critères Communs :
  - atteste qu'un évaluateur indépendant a vérifié que le produit possède les fonctions de sécurité définies par l'industriel dans la cible de sécurité ;
  - nécessite que l'acquéreur lise la cible de sécurité et vérifie que les fonctions évaluées correspondent à son besoin.

Comment choisir ses produits de sécurité ?



- Un produit **certifié** Critères Communs :
  - atteste qu'un évaluateur indépendant a vérifié que le produit possède les fonctions de sécurité définies par l'industriel dans la cible de sécurité ;
  - nécessite que l'acquéreur lise la cible de sécurité et vérifie que les fonctions évaluées correspondent à son besoin.
- Un produit **qualifié** par l'ANSSI :

Comment choisir ses produits de sécurité ?



- Un produit **certifié** Critères Communs :
  - atteste qu'un évaluateur indépendant a vérifié que le produit possède les fonctions de sécurité définies par l'industriel dans la cible de sécurité ;
  - nécessite que l'acquéreur lise la cible de sécurité et vérifie que les fonctions évaluées correspondent à son besoin.
- Un produit **qualifié** par l'ANSSI :
  - atteste que l'ANSSI a validé les fonctions de sécurité nécessaires au produit ;

Comment choisir ses produits de sécurité ?



- Un produit **certifié** Critères Communs :
  - atteste qu'un évaluateur indépendant a vérifié que le produit possède les fonctions de sécurité définies par l'industriel dans la cible de sécurité ;
  - nécessite que l'acquéreur lise la cible de sécurité et vérifie que les fonctions évaluées correspondent à son besoin.
- Un produit **qualifié** par l'ANSSI :
  - atteste que l'ANSSI a validé les fonctions de sécurité nécessaires au produit ;
  - est recommandé par l'ANSSI, parfois réglementairement imposé.

Comment choisir ses produits de sécurité ?



- Un produit **certifié** Critères Communs :
  - atteste qu'un évaluateur indépendant a vérifié que le produit possède les fonctions de sécurité définies par l'industriel dans la cible de sécurité ;
  - nécessite que l'acquéreur lise la cible de sécurité et vérifie que les fonctions évaluées correspondent à son besoin.
- Un produit **qualifié** par l'ANSSI :
  - atteste que l'ANSSI a validé les fonctions de sécurité nécessaires au produit ;
  - est recommandé par l'ANSSI, parfois réglementairement imposé.
- Un produit **agréé** par l'ANSSI (NCSC approved for NATO) :

Comment choisir ses produits de sécurité ?



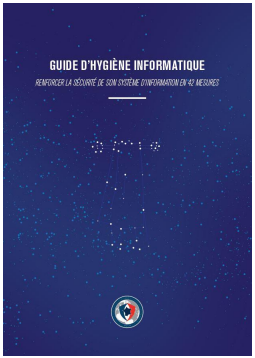
- Un produit **certifié** Critères Communs :
  - atteste qu'un évaluateur indépendant a vérifié que le produit possède les fonctions de sécurité définies par l'industriel dans la cible de sécurité ;
  - nécessite que l'acquéreur lise la cible de sécurité et vérifie que les fonctions évaluées correspondent à son besoin.
- Un produit **qualifié** par l'ANSSI :
  - atteste que l'ANSSI a validé les fonctions de sécurité nécessaires au produit ;
  - est recommandé par l'ANSSI, parfois réglementairement imposé.
- Un produit **agréé** par l'ANSSI (NCSC approved for NATO) :
  - est obligatoire pour la protection d'informations *diffusion restreinte* ou classifiées de défense ;

Comment choisir ses produits de sécurité ?



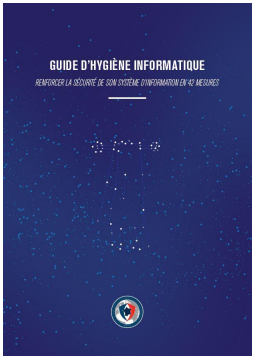
- Un produit **certifié** Critères Communs :
  - atteste qu'un évaluateur indépendant a vérifié que le produit possède les fonctions de sécurité définies par l'industriel dans la cible de sécurité ;
  - nécessite que l'acquéreur lise la cible de sécurité et vérifie que les fonctions évaluées correspondent à son besoin.
- Un produit **qualifié** par l'ANSSI :
  - atteste que l'ANSSI a validé les fonctions de sécurité nécessaires au produit ;
  - est recommandé par l'ANSSI, parfois réglementairement imposé.
- Un produit **agréé** par l'ANSSI (NCSC approved for NATO) :
  - est obligatoire pour la protection d'informations *diffusion restreinte* ou classifiées de défense ;
  - la décision d'agrément est associée à un niveau de sensibilité ou de classification.

Une bonne architecture de sécurité n'est pas suffisante



Guide hygiène informatique

Une bonne architecture de sécurité n'est pas suffisante

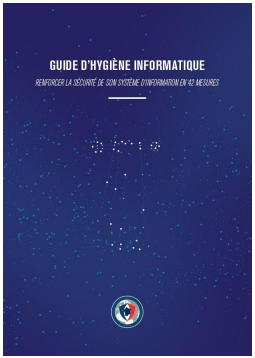


Guide hygiène informatique

Il est également nécessaire de :

- l'application des correctifs de sécurité pour les équipements et logiciels dans un temps raisonnable ;

Une bonne architecture de sécurité n'est pas suffisante

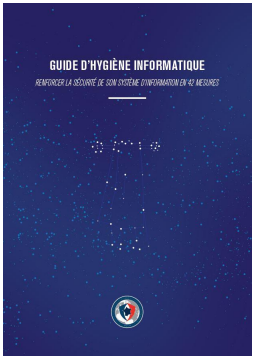


Guide hygiène informatique

Il est également nécessaire de :

- l'application des correctifs de sécurité pour les équipements et logiciels dans un temps raisonnable ;
- réaliser régulièrement des audits de sécurité ;

Une bonne architecture de sécurité n'est pas suffisante

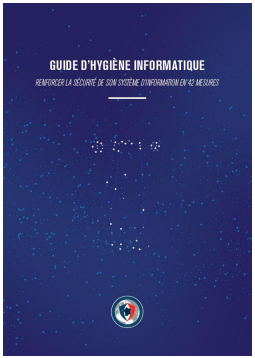


Guide hygiène informatique

Il est également nécessaire de :

- l'application des correctifs de sécurité pour les équipements et logiciels dans un temps raisonnable ;
- réaliser régulièrement des audits de sécurité ;
- assurer la sensibilisation des utilisateurs et la formation des administrateurs ;

Une bonne architecture de sécurité n'est pas suffisante



Guide hygiène informatique

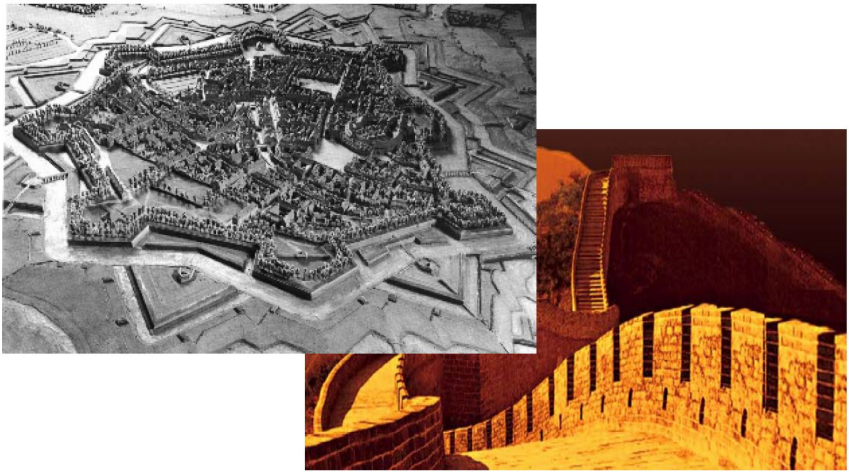
Il est également nécessaire de :

- l'application des correctifs de sécurité pour les équipements et logiciels dans un temps raisonnable ;
- réaliser régulièrement des audits de sécurité ;
- assurer la sensibilisation des utilisateurs et la formation des administrateurs ;
- concevoir, mettre en oeuvre et tester des plans de continuité et de reprise d'activité ;

Plan

2 Principes généraux d'architecture sécurisée
- Qu'est-ce qu'une architecture sécurisée ?
- Principes et modèles de sécurité des SI
- Exemple de modèles de sécurité formels

Défense en profondeur



Défense en profondeur

La défense en profondeur est un concept militaire, utilisé depuis au moins le Moyen-Âge.

- peut s'appliquer à un niveau stratégique (guerre de mouvement), à un niveau tactique (architecture concentrique de château) ;

Défense en profondeur

La défense en profondeur est un concept militaire, utilisé depuis au moins le Moyen-Âge.

- peut s'appliquer à un niveau stratégique (guerre de mouvement), à un niveau tactique (architecture concentrique de château) ;
- consiste en l'utilisation de plusieurs barrières de défense ;

Défense en profondeur

La défense en profondeur est un concept militaire, utilisé depuis au moins le Moyen-Âge.

- peut s'appliquer à un niveau stratégique (guerre de mouvement), à un niveau tactique (architecture concentrique de château) ;
- consiste en l'utilisation de plusieurs barrières de défense ;
- dont le but est d'échanger du **terrain** contre du **temps** et des **ressources** ;

Défense en profondeur

La défense en profondeur est un concept militaire, utilisé depuis au moins le Moyen-Âge.

- peut s'appliquer à un niveau stratégique (guerre de mouvement), à un niveau tactique (architecture concentrique de château) ;
- consiste en l'utilisation de plusieurs barrières de défense ;
- dont le but est d'échanger du **terrain** contre du **temps** et des **ressources** ;

la défense en profondeur dans le domaine de la SSI :

- est connue depuis longtemps, mais rarement bien mise-en-œuvre ;

Défense en profondeur

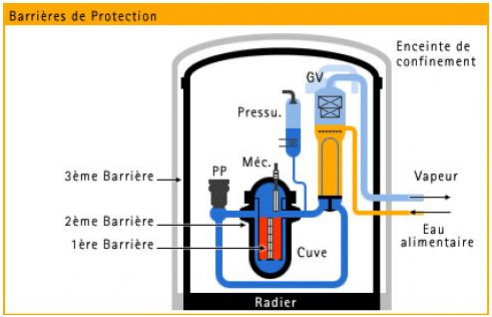
La défense en profondeur est un concept militaire, utilisé depuis au moins le Moyen-Âge.

- peut s'appliquer à un niveau stratégique (guerre de mouvement), à un niveau tactique (architecture concentrique de château) ;
- consiste en l'utilisation de plusieurs barrières de défense ;
- dont le but est d'échanger du **terrain** contre du **temps** et des **ressources** ;

la défense en profondeur dans le domaine de la SSI :

- est connue depuis longtemps, mais rarement bien mise-en-œuvre ;
- est indispensable pour se protéger contre les attaques de plus en plus sophistiquées des *Advanced Persistent Threats* ;

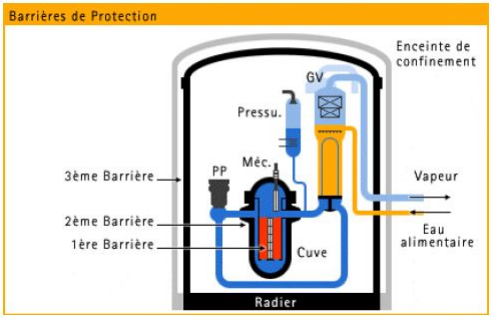
La défense en profondeur dans le domaine de la sûreté



Dans un réacteur nucléaire, il y au moins 3 barrières pour réduire le risque d'une fusion du réacteur :

- les tubes de combustibles sont entourés d'un revêtement en céramique (rouge) ;

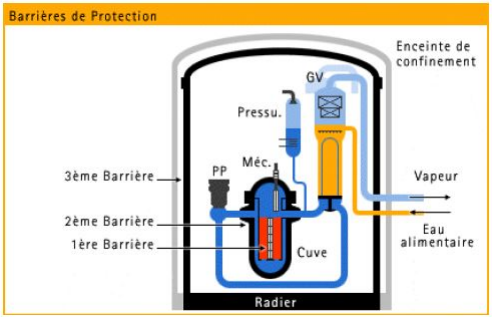
La défense en profondeur dans le domaine de la sûreté



Dans un réacteur nucléaire, il y au moins 3 barrières pour réduire le risque d'une fusion du réacteur :

- les tubes de combustibles sont entourés d'un revêtement en céramique (rouge) ;
- les tubes sont dans une cuve d'eau dont l'épaisseur est d'au minimum 20cm d'acier ;

La défense en profondeur dans le domaine de la sûreté



Dans un réacteur nucléaire, il y au moins 3 barrières pour réduire le risque d'une fusion du réacteur :

- les tubes de combustibles sont entourés d'un revêtement en céramique (rouge) ;
- les tubes sont dans une cuve d'eau dont l'épaisseur est d'au minimum 20cm d'acier ;
- la cuve est confinée dans une enceinte d'une épaisseur d'au minimum 90cm de béton ;

la défense en profondeur en SSI

la défense en profondeur en SSI

Une stratégie de sécurité de l'information qui intègre les personnes, la technologie et les capacités opérationnelles pour établir différentes barrières sur différentes strates et missions de l'organisation.

- multiplier les fonctions de sécurité pour limiter les conséquences de la perte de l'une d'entre elles ;



la défense en profondeur en SSI

la défense en profondeur en SSI

Une stratégie de sécurité de l'information qui intègre les personnes, la technologie et les capacités opérationnelles pour établir différentes barrières sur différentes strates et missions de l'organisation.

- multiplier les fonctions de sécurité pour limiter les conséquences de la perte de l'une d'entre elles ;
- rendre indépendantes les fonctions de sécurité (technologie, couche OSI) ;



la défense en profondeur en SSI

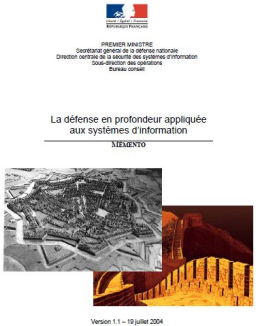
la défense en profondeur en SSI

Une stratégie de sécurité de l'information qui intègre les personnes, la technologie et les capacités opérationnelles pour établir différentes barrières sur différentes strates et missions de l'organisation.

- multiplier les fonctions de sécurité pour limiter les conséquences de la perte de l'une d'entre elles ;
- rendre indépendantes les fonctions de sécurité (technologie, couche OSI) ;
- surveiller les fonctions de sécurité pour pouvoir détecter au plus vite un incident.



Pour aller plus loin sur la défense en profondeur



Memento sur la défense en profondeur appliquée aux systèmes d'information

- Publié par l'ANSSI (DCSSI) en 2003 ;
- https ://www.ssi.gouv.fr/guide/la-defense-en-profondeur-appliquee-aux-systemes-dinformation/

Définitions du NIST

Un domaine de sécurité (security domain) :

Environnement ou contexte comprenant un ensemble de ressources système et un ensemble d'entités système ayant le droit d'accéder aux ressources, tel que défini par une politique de sécurité, un modèle de sécurité ou une architecture de sécurité communs. *NIST SP 800-53*

Un périmètre de sécurité (security perimeter) :

Une limite physique ou logique définie pour un système, un domaine ou une enclave, à l'intérieur de laquelle une politique ou une architecture de sécurité particulière est appliquée. *CNSSI 4009-2015*

Zones de confiance

Les critères utilisés pour délimiter une zone de confiance peuvent être :

- criticité métier (ex. : haute, moyenne, basse) ;
- organisation (ex. : administration interne ou infogérée) ;
- exposition (ex. : à Internet, à des fournisseurs, exclusivement interne) ;
- réglementation (ex. : données de santé, données personnelles, données relevant du secret de la défense nationale)
- géographie (ex. : découpage par pays).

Défense périmétrique

Défense périmétrique

La **défense périmétrique** est un principe de cloisonnement applicable entre au moins deux zones, généralement l'une « interne » et l'autre « externe » de moindre confiance.

Défense périmétrique

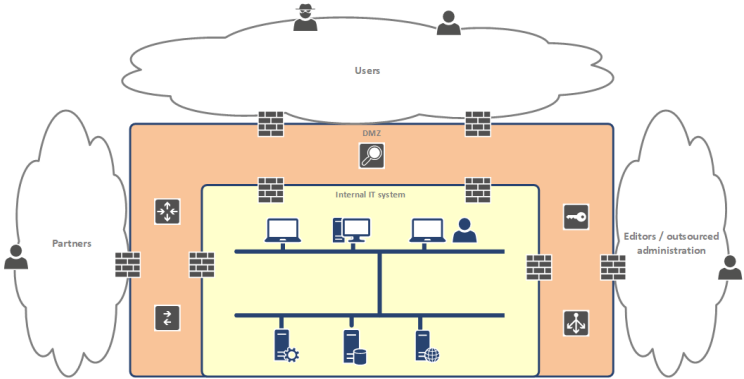
Défense périmétrique

La **défense périmétrique** est un principe de cloisonnement applicable entre au moins deux zones, généralement l'une « interne » et l'autre « externe » de moindre confiance.

La défense périmétrique est :

- très adaptée aux SI de périmètre maîtrisé (modèle de la forteresse) ;
- généralement mise en œuvre par des pare-feux réseau, parfois complétée par des sondes de détection.

modèle de la forteresse



modèle de la forteresse

modèle de la forteresse

Le modèle de la forteresse :

- Hypothèses principales ;

modèle de la forteresse

Le modèle de la forteresse :

- Hypothèses principales ;
  - les menaces ne proviennent que de l'extérieur ;

modèle de la forteresse

Le modèle de la forteresse :

- Hypothèses principales ;
  - les menaces ne proviennent que de l'extérieur ;
  - tout ce qui est à l'intérieur du périmètre maîtrisé est de confiance ;

modèle de la forteresse

Le modèle de la forteresse :

- Hypothèses principales ;
  - les menaces ne proviennent que de l'extérieur ;
  - tout ce qui est à l'intérieur du périmètre maîtrisé est de confiance ;
- ce modèle a fonctionné jusqu'à la fin du XXe siècle ;

modèle de la forteresse

Le modèle de la forteresse :

- Hypothèses principales ;
  - les menaces ne proviennent que de l'extérieur ;
  - tout ce qui est à l'intérieur du périmètre maîtrisé est de confiance ;
- ce modèle a fonctionné jusqu'à la fin du XXe siècle ;
  - les premiers virus des années 70-80 étaient des sujets académiques peu répandus ;

modèle de la forteresse

Le modèle de la forteresse :

- Hypothèses principales ;
  - les menaces ne proviennent que de l'extérieur ;
  - tout ce qui est à l'intérieur du périmètre maîtrisé est de confiance ;
- ce modèle a fonctionné jusqu'à la fin du XXe siècle ;
  - les premiers virus des années 70-80 étaient des sujets académiques peu répandus ;
  - les attaques étaient souvent peu sophistiquées et peu organisées ;

modèle de la forteresse

Le modèle de la forteresse :

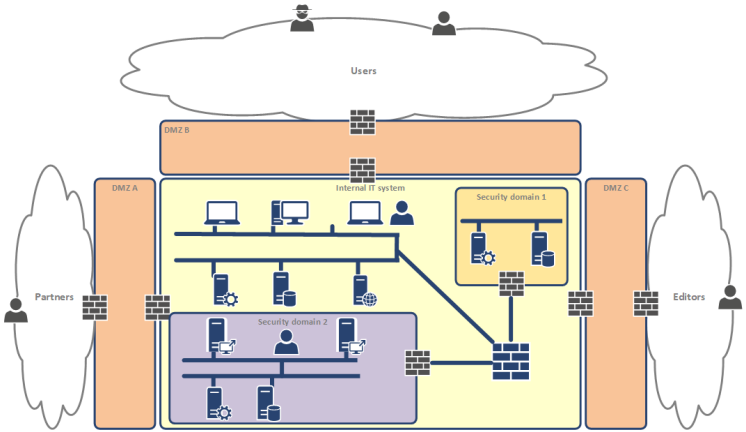
- Hypothèses principales ;
  - les menaces ne proviennent que de l'extérieur ;
  - tout ce qui est à l'intérieur du périmètre maîtrisé est de confiance ;
- ce modèle a fonctionné jusqu'à la fin du XXe siècle ;
  - les premiers virus des années 70-80 étaient des sujets académiques peu répandus ;
  - les attaques étaient souvent peu sophistiquées et peu organisées ;
  - les interconnexions de systèmes étaient moins courantes, et plus limitées ;

modèle de la forteresse

Le modèle de la forteresse :

- Hypothèses principales ;
  - les menaces ne proviennent que de l'extérieur ;
  - tout ce qui est à l'intérieur du périmètre maîtrisé est de confiance ;
- ce modèle a fonctionné jusqu'à la fin du XXe siècle ;
  - les premiers virus des années 70-80 étaient des sujets académiques peu répandus ;
  - les attaques étaient souvent peu sophistiquées et peu organisées ;
  - les interconnexions de systèmes étaient moins courantes, et plus limitées ;
  - le premier ver très répandu, ILOVEYOU, est apparu en 2000.

le modèle aéroport



le modèle de l'aéroport

le modèle de l'aéroport

Le modèle de l'aéroport :

- Hypothèses principales ;

le modèle de l'aéroport

Le modèle de l'aéroport :

- Hypothèses principales ;
  - les attaques peuvent provenir de l'intérieur comme de l'extérieur ;

le modèle de l'aéroport

Le modèle de l'aéroport :

- Hypothèses principales ;
  - les attaques peuvent provenir de l'intérieur comme de l'extérieur ;
  - repose sur la défense périmètrique, comme le modèle forteresse, mais définit des zones de confiances internes ;

le modèle de l'aéroport

Le modèle de l'aéroport :

- Hypothèses principales ;
  - les attaques peuvent provenir de l'intérieur comme de l'extérieur ;
  - repose sur la défense périmètrique, comme le modèle forteresse, mais définit des zones de confiances internes ;
- ce modèle prend en compte ;

le modèle de l'aéroport

Le modèle de l'aéroport :

- Hypothèses principales ;
  - les attaques peuvent provenir de l'intérieur comme de l'extérieur ;
  - repose sur la défense périmètrique, comme le modèle forteresse, mais définit des zones de confiances internes ;
- ce modèle prend en compte ;
  - le niveau d'exposition des composants ;

le modèle de l'aéroport

Le modèle de l'aéroport :

- Hypothèses principales ;
  - les attaques peuvent provenir de l'intérieur comme de l'extérieur ;
  - repose sur la défense périmètrique, comme le modèle forteresse, mais définit des zones de confiances internes ;
- ce modèle prend en compte ;
  - le niveau d'exposition des composants ;
  - la criticité opérationnelle des composants ;

Zero Trust {Network, Architecture, Principle}

Zero Trust (ZTx)

Zero Trust Network (ou zero trust architecture, zero trust network architecture, sécurité sans périmètre) est un modèle de sécurité des systèmes d'information. Le concept principal est *never trust, always verify*, c'est-à-dire que l'on doit considérer que tout élement du SI, ou presque, peut-être compromis.

Zero Trust {Network, Architecture, Principle}

Zero Trust (ZTx)

Zero Trust Network (ou zero trust architecture, zero trust network architecture, sécurité sans périmètre) est un modèle de sécurité des systèmes d'information. Le concept principal est *never trust, always verify*, c'est-à-dire que l'on doit considérer que tout élement du SI, ou presque, peut-être compromis.

Les principes du ZT :

- Par défaut, aucun composant n'est de confiance, la confiance doit être établie ;

Zero Trust {Network, Architecture, Principle}

Zero Trust (ZTx)

Zero Trust Network (ou zero trust architecture, zero trust network architecture, sécurité sans périmètre) est un modèle de sécurité des systèmes d'information. Le concept principal est *never trust, always verify*, c'est-à-dire que l'on doit considérer que tout élement du SI, ou presque, peut-être compromis.

Les principes du ZT :

- Par défaut, aucun composant n'est de confiance, la confiance doit être établie ;
- Le niveau de confiance est mesuré continuellement ;

Zero Trust {Network, Architecture, Principle}

Zero Trust (ZTx)

Zero Trust Network (ou zero trust architecture, zero trust network architecture, sécurité sans périmètre) est un modèle de sécurité des systèmes d'information. Le concept principal est *never trust, always verify*, c'est-à-dire que l'on doit considérer que tout élement du SI, ou presque, peut-être compromis.

Les principes du ZT :

- Par défaut, aucun composant n'est de confiance, la confiance doit être établie ;
- Le niveau de confiance est mesuré continuellement ;
- Les autorisations sont données sur la base du moindre privilège, idéalement par requête ;

Zero Trust {Network, Architecture, Principle}

Zero Trust (ZTx)

Zero Trust Network (ou zero trust architecture, zero trust network architecture, sécurité sans périmètre) est un modèle de sécurité des systèmes d'information. Le concept principal est *never trust, always verify*, c'est-à-dire que l'on doit considérer que tout élement du SI, ou presque, peut-être compromis.

Les principes du ZT :

- Par défaut, aucun composant n'est de confiance, la confiance doit être établie ;
- Le niveau de confiance est mesuré continuellement ;
- Les autorisations sont données sur la base du moindre privilège, idéalement par requête ;
- Les données sont toujours transmises chiffrées, peu importe le réseau de transport.

Analogie ZTN : la salle des preuves





- Que se passe-t-il si quelqu'un réussi à entrer ?

Analogie ZTN : la salle des preuves





- Que se passe-t-il si quelqu'un réussi à entrer ?
- Que se passe-t-il si un policier accèdes aux preuve d'une autre affaire ?

Analogie ZTN : la salle des preuves





- Que se passe-t-il si quelqu'un réussi à entrer ?
- Que se passe-t-il si un policier accèdes aux preuve d'une autre affaire ?
- Que se passe-t-il si le garde est corrompu ?

Analogie ZTN : la salle des preuves





- Que se passe-t-il si quelqu'un réussi à entrer ?
- Que se passe-t-il si un policier accèdes aux preuve d'une autre affaire ?
- Que se passe-t-il si le garde est corrompu ?

Le modèle Zero Trust par le NIST

Key components :

- Policy Enforcement Point : établit, surveille, et termine les connexions ;
- Policy Engine : délivre les autorisations d'accès ;
- Policy Administrator : commande le PEP.

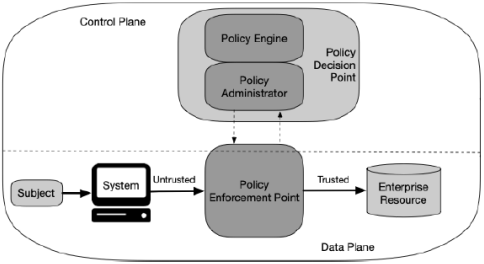


Figure – Source : Zero Trust Architecture, SP. 800-207, NIST, 2020

Zero Trust : Et les périmètres dans tout ça ?

Est-ce que la défense périmétrique est toujours pertinente avec le *Zero Trust* ?



Zero Trust Network : points clés

Le modèle ZTN :

- est très pertinent lorsque la défense périmétrique n'est pas possible (cloud public, nomadisme peu sécurisé) ;

Zero Trust Network : points clés

Le modèle ZTN :

- est très pertinent lorsque la défense périmétrique n'est pas possible (cloud public, nomadisme peu sécurisé) ;
- renforce la sécurité dans une logique de défense en profondeur ;

Zero Trust Network : points clés

Le modèle ZTN :

- est très pertinent lorsque la défense périmétrique n'est pas possible (cloud public, nomadisme peu sécurisé) ;
- renforce la sécurité dans une logique de défense en profondeur ;
- n'est pas une technologie, il n'y a pas de produit tout en un.

Zero Trust Network : points clés

Le modèle ZTN :

- est très pertinent lorsque la défense périmétrique n'est pas possible (cloud public, nomadisme peu sécurisé) ;
- renforce la sécurité dans une logique de défense en profondeur ;
- n'est pas une technologie, il n'y a pas de produit tout en un.

Zero Trust Network : points clés

Le modèle ZTN :

- est très pertinent lorsque la défense périmétrique n'est pas possible (cloud public, nomadisme peu sécurisé) ;
- renforce la sécurité dans une logique de défense en profondeur ;
- n'est pas une technologie, il n'y a pas de produit tout en un.

Attention à l'effet de mode :

- Le ZTN ne doit pas remplacer la défense périmétrique ;

Zero Trust Network : points clés

Le modèle ZTN :

- est très pertinent lorsque la défense périmétrique n'est pas possible (cloud public, nomadisme peu sécurisé) ;
- renforce la sécurité dans une logique de défense en profondeur ;
- n'est pas une technologie, il n'y a pas de produit tout en un.

Attention à l'effet de mode :

- Le ZTN ne doit pas remplacer la défense périmétrique ;
- Le ZTN est souvent, actuellement, applicable à des parties limitées d'un SI ;

Zero Trust Network : points clés

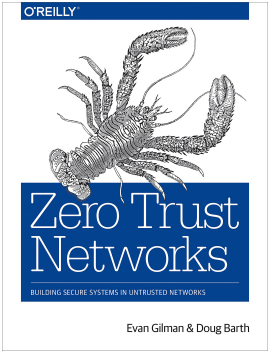
Le modèle ZTN :

- est très pertinent lorsque la défense périmétrique n'est pas possible (cloud public, nomadisme peu sécurisé) ;
- renforce la sécurité dans une logique de défense en profondeur ;
- n'est pas une technologie, il n'y a pas de produit tout en un.

Attention à l'effet de mode :

- Le ZTN ne doit pas remplacer la défense périmétrique ;
- Le ZTN est souvent, actuellement, applicable à des parties limitées d'un SI ;
- Le ZTN dépend d'un référentiel d'identité de confiance.

Plus de lecture sur le ZTN



Recommended readings :

- Zero Trust Networks Building Secure Systems in Untrusted Networks - Evan Gilman & Doug Barth ;
- NIST SP 800-207 Zero Trust Architecture : https ://csrc.nist.gov/publications/detail/sp/800-207/final
- ANSSI Le modèle Zero Trust : https ://www.ssi.gouv.fr/agence/publication/le-modele-zero-trust/

Plan

2 Principes généraux d'architecture sécurisée
- Qu'est-ce qu'une architecture sécurisée ?
- Principes et modèles de sécurité des SI
- Exemple de modèles de sécurité formels

Le modèle de sécurité Bell-Lapadula

Le modèle de sécurité Bell-Lapadula

Le modèle Bell–LaPadula (BLP) est un modèle de machine à état utilisé pour le contrôle d'accès, notamment utilisé dans le domaine gourvernemental et militaire. Le modèle décrit un ensemble de règles de contrôle, qui utilisent des labels de sécurité sur les objets et des habilitations de sécurité pour les sujets. Les labels peuvent aller du plus sensible (p. ex. "'Très Secret"') au moins sensible (p. ex. "'Public"').

Confidentialité

Le modèle de Bell-Lapadula a pour objectif de protéger la confidentialité des objets.

Le modèle de sécurité Bell-Lapadula

Les propriétés du modèle Bell-Lapadula :

- La Simple Security Property : un sujet ne peut pas lire le contenu d'un objet à un niveau de sécurité supérieur au sien (no read up) ;

Le modèle de sécurité Bell-Lapadula

Les propriétés du modèle Bell-Lapadula :

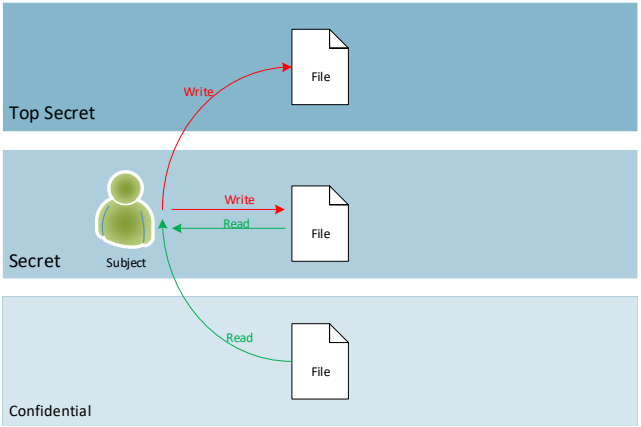
- La Simple Security Property : un sujet ne peut pas lire le contenu d'un objet à un niveau de sécurité supérieur au sien (no read up) ;
- La * (star)Security Property : un sujet ne peut pas écrire le contenu d'un objet à un niveau de sécurité inférieur au sien (no write down) ;

Le modèle de sécurité Bell-Lapadula

Les propriétés du modèle Bell-Lapadula :

- La Simple Security Property : un sujet ne peut pas lire le contenu d'un objet à un niveau de sécurité supérieur au sien (no read up) ;
- La * (star)Security Property : un sujet ne peut pas écrire le contenu d'un objet à un niveau de sécurité inférieur au sien (no write down) ;
- La Discretionary Security Property utilise une matrice de contrôle d'accès pour définir le contrôle d'accès discrétionnaire.

Le modèle de sécurité Bell-Lapadula



Le modèle de sécurité Biba

Biba security model

Le modèle de sécurité Biba est un modèle de machine à état utilisé pour le contrôle d'accès, qui se concentre sur la protection de l'intégrité des données. Les données et les sujets sont groupés par niveau d'intégrité. Le modèle est conçu de sorte à ce qu'un sujet ne puisse pas corrompre les données d'un niveau d'intégrité qui lui est supérieur, ou être corrompu par des données provenant d'un niveau d'intégrité inférieur.

Intégrité

Le modèle de Biba vis à protéger l'intégrité des données.

Le modèle de sécurité Biba

Les propriétés du modèle de sécurité Biba :

- The Simple Integrity Property : un sujet ne peut pas lire le contenu d'un objet possédant un niveau d'intégrité inférieur (no read down) ;

Le modèle de sécurité Biba

Les propriétés du modèle de sécurité Biba :

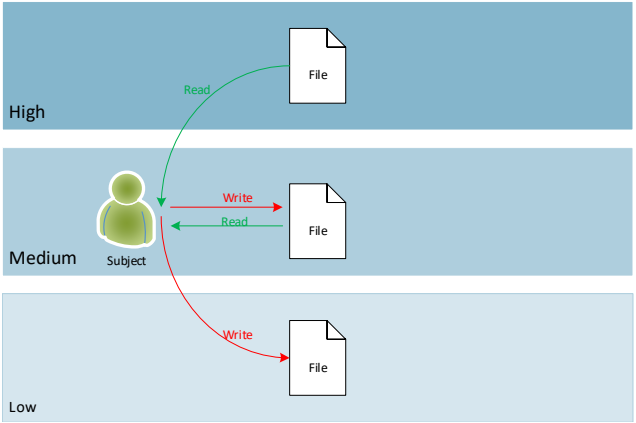
- The Simple Integrity Property : un sujet ne peut pas lire le contenu d'un objet possédant un niveau d'intégrité inférieur (no read down) ;
- The * (star) Integrity Property : un sujet ne peut pas écrire le contenu d'un objet possédant un niveau d'intégrité supérieur (no write up) ;

Le modèle de sécurité Biba

Les propriétés du modèle de sécurité Biba :

- The Simple Integrity Property : un sujet ne peut pas lire le contenu d'un objet possédant un niveau d'intégrité inférieur (no read down) ;
- The * (star) Integrity Property : un sujet ne peut pas écrire le contenu d'un objet possédant un niveau d'intégrité supérieur (no write up) ;
- Invocation Property : un process d'un niveau donné ne peut pas invoquer un process d'un niveau d'intégrité supérieur.

Le modèle de sécurité Biba



Plan

1 Introduction

2 Principes généraux d'architecture sécurisée

3 Socle de connaissances

4 Étude de cas : passerelle d'interconnexion à Internet

5 Conclusion

Adapter son point de vue

- Les cours théoriques (système, réseau...) permettent de comprendre des objets techniques :

Adapter son point de vue

- Les cours théoriques (système, réseau...) permettent de comprendre des objets techniques :
  - comment ils fonctionnent ;

Adapter son point de vue

- Les cours théoriques (système, réseau...) permettent de comprendre des objets techniques :
  - comment ils fonctionnent ;
  - comment les mettre en oeuvre ;

Adapter son point de vue

- Les cours théoriques (système, réseau...) permettent de comprendre des objets techniques :
  - comment ils fonctionnent ;
  - comment les mettre en oeuvre ;
  - quelles sont leurs limites intrinsèques ;

Adapter son point de vue

- Les cours théoriques (système, réseau...) permettent de comprendre des objets techniques :
  - comment ils fonctionnent ;
  - comment les mettre en oeuvre ;
  - quelles sont leurs limites intrinsèques ;
- Le point de vue nécessaire pour l'architecte :

Adapter son point de vue

- Les cours théoriques (système, réseau...) permettent de comprendre des objets techniques :
  - comment ils fonctionnent ;
  - comment les mettre en oeuvre ;
  - quelles sont leurs limites intrinsèques ;
- Le point de vue nécessaire pour l'architecte :
  - à quoi sert un objet technique, quelle est sa fonction ;

Adapter son point de vue

- Les cours théoriques (système, réseau...) permettent de comprendre des objets techniques :
  - comment ils fonctionnent ;
  - comment les mettre en oeuvre ;
  - quelles sont leurs limites intrinsèques ;
- Le point de vue nécessaire pour l'architecte :
  - à quoi sert un objet technique, quelle est sa fonction ;
  - quelles sont les contraintes à utiliser un objet plutôt qu'un autre ;

Adapter son point de vue

- Les cours théoriques (système, réseau...) permettent de comprendre des objets techniques :
  - comment ils fonctionnent ;
  - comment les mettre en oeuvre ;
  - quelles sont leurs limites intrinsèques ;
- Le point de vue nécessaire pour l'architecte :
  - à quoi sert un objet technique, quelle est sa fonction ;
  - quelles sont les contraintes à utiliser un objet plutôt qu'un autre ;
  - quelles combinaisons de fonctions répondent au besoin en minimisant les contraintes ;

Le parefeu

- Fonction : délimiter les zones de sécurité :

Le parefeu

- Fonction : délimiter les zones de sécurité :
  - fait respecter des contraintes sur les flux ;

Le parefeu

- Fonction : délimiter les zones de sécurité :
  - fait respecter des contraintes sur les flux ;
  - entre plusieurs plan d'adressage IP ;

Le parefeu

- Fonction : délimiter les zones de sécurité :
  - fait respecter des contraintes sur les flux ;
  - entre plusieurs plan d'adressage IP ;
- Contraintes d'utilisation :

Le parefeu

- Fonction : délimiter les zones de sécurité :
  - fait respecter des contraintes sur les flux ;
  - entre plusieurs plan d'adressage IP ;
- Contraintes d'utilisation :
  - agit sur les couches bases du modèle OSI ;

Le parefeu

- Fonction : délimiter les zones de sécurité :
  - fait respecter des contraintes sur les flux ;
  - entre plusieurs plan d'adressage IP ;
- Contraintes d'utilisation :
  - agit sur les couches bases du modèle OSI ;
  - exige une topologie réseau adaptée : un plan IP = un réseau physique ou Vlan, répartition des autres machines sur les plan IP, donc sur des réseaux séparés (physiques ou virtuels) ;

Le parefeu

- Fonction : délimiter les zones de sécurité :
  - fait respecter des contraintes sur les flux ;
  - entre plusieurs plan d'adressage IP ;
- Contraintes d'utilisation :
  - agit sur les couches bases du modèle OSI ;
  - exige une topologie réseau adaptée : un plan IP = un réseau physique ou Vlan, répartition des autres machines sur les plan IP, donc sur des réseaux séparés (physiques ou virtuels) ;
  - nécessite un positionnement en coupure : équipement actif (filtrage distant) ou processus privilégié (filtrage local) ;

Le parefeu

- Fonction : délimiter les zones de sécurité :
  - fait respecter des contraintes sur les flux ;
  - entre plusieurs plan d'adressage IP ;
- Contraintes d'utilisation :
  - agit sur les couches bases du modèle OSI ;
  - exige une topologie réseau adaptée : un plan IP = un réseau physique ou Vlan, répartition des autres machines sur les plan IP, donc sur des réseaux séparés (physiques ou virtuels) ;
  - nécessite un positionnement en coupure : équipement actif (filtrage distant) ou processus privilégié (filtrage local) ;
  - MCO : mettre à jour l'OS, les logiciels spécifique (scripts), son interface d'admin (console web locale ou déportée) ;

Le parefeu

- Fonction : délimiter les zones de sécurité :
  - fait respecter des contraintes sur les flux ;
  - entre plusieurs plan d'adressage IP ;
- Contraintes d'utilisation :
  - agit sur les couches bases du modèle OSI ;
  - exige une topologie réseau adaptée : un plan IP = un réseau physique ou Vlan, répartition des autres machines sur les plan IP, donc sur des réseaux séparés (physiques ou virtuels) ;
  - nécessite un positionnement en coupure : équipement actif (filtrage distant) ou processus privilégié (filtrage local) ;
  - MCO : mettre à jour l'OS, les logiciels spécifique (scripts), son interface d'admin (console web locale ou déportée) ;
  - MCS : maintenir les règles, protéger l'interface d'admin...

Le proxy

- Fonction : maîtriser la navigation vers Internet :

Le proxy

- Fonction : maîtriser la navigation vers Internet :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;

Le proxy

- Fonction : maîtriser la navigation vers Internet :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - filtrage (inspection des requêtes HTTP, SSH..., listes d'accès/refus par domaine), affiné si l'utilisateur est authentifié ;

Le proxy

- Fonction : maîtriser la navigation vers Internet :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - filtrage (inspection des requêtes HTTP, SSH..., listes d'accès/refus par domaine), affiné si l'utilisateur est authentifié ;
  - journalisation de l'activité

Le proxy

- Fonction : maîtriser la navigation vers Internet :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - filtrage (inspection des requêtes HTTP, SSH..., listes d'accès/refus par domaine), affiné si l'utilisateur est authentifié ;
  - journalisation de l'activité
  - accélération (mémoire cache et compression de données)

Le proxy

- Fonction : maîtriser la navigation vers Internet :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - filtrage (inspection des requêtes HTTP, SSH..., listes d'accès/refus par domaine), affiné si l'utilisateur est authentifié ;
  - journalisation de l'activité
  - accélération (mémoire cache et compression de données)
  - répartition de charge (liens réseaux vers Internet)

Le proxy

- Fonction : maîtriser la navigation vers Internet :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - filtrage (inspection des requêtes HTTP, SSH..., listes d'accès/refus par domaine), affiné si l'utilisateur est authentifié ;
  - journalisation de l'activité
  - accélération (mémoire cache et compression de données)
  - répartition de charge (liens réseaux vers Internet)
  - anonymisation (relative)

Le proxy

- Fonction : maîtriser la navigation vers Internet :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - filtrage (inspection des requêtes HTTP, SSH..., listes d'accès/refus par domaine), affiné si l'utilisateur est authentifié ;
  - journalisation de l'activité
  - accélération (mémoire cache et compression de données)
  - répartition de charge (liens réseaux vers Internet)
  - anonymisation (relative)
  - inspection TLS (attention aux risques)

Le proxy

- Fonction : maîtriser la navigation vers Internet :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - filtrage (inspection des requêtes HTTP, SSH..., listes d'accès/refus par domaine), affiné si l'utilisateur est authentifié ;
  - journalisation de l'activité
  - accélération (mémoire cache et compression de données)
  - répartition de charge (liens réseaux vers Internet)
  - anonymisation (relative)
  - inspection TLS (attention aux risques)
- Contraintes d'utilisation :

Le proxy

- Fonction : maîtriser la navigation vers Internet :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - filtrage (inspection des requêtes HTTP, SSH..., listes d'accès/refus par domaine), affiné si l'utilisateur est authentifié ;
  - journalisation de l'activité
  - accélération (mémoire cache et compression de données)
  - répartition de charge (liens réseaux vers Internet)
  - anonymisation (relative)
  - inspection TLS (attention aux risques)
- Contraintes d'utilisation :
  - cf. parefeu

Le proxy

- Fonction : maîtriser la navigation vers Internet :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - filtrage (inspection des requêtes HTTP, SSH..., listes d'accès/refus par domaine), affiné si l'utilisateur est authentifié ;
  - journalisation de l'activité
  - accélération (mémoire cache et compression de données)
  - répartition de charge (liens réseaux vers Internet)
  - anonymisation (relative)
  - inspection TLS (attention aux risques)
- Contraintes d'utilisation :
  - cf. parefeu
  - authentification = lien avec un annuaire

Le proxy

- Fonction : maîtriser la navigation vers Internet :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - filtrage (inspection des requêtes HTTP, SSH..., listes d'accès/refus par domaine), affiné si l'utilisateur est authentifié ;
  - journalisation de l'activité
  - accélération (mémoire cache et compression de données)
  - répartition de charge (liens réseaux vers Internet)
  - anonymisation (relative)
  - inspection TLS (attention aux risques)
- Contraintes d'utilisation :
  - cf. parefeu
  - authentification = lien avec un annuaire
  - journalisation = collecter les journaux

Le reverse-proxy

- Fonction : protéger des serveurs (web) exposés :

Le reverse-proxy

- Fonction : protéger des serveurs (web) exposés :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;

Le reverse-proxy

- Fonction : protéger des serveurs (web) exposés :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - Web Application Firewall (inspection des requêtes HTTP, SSH..., des champs et paramètres passé dans la requête) ;

Le reverse-proxy

- Fonction : protéger des serveurs (web) exposés :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - Web Application Firewall (inspection des requêtes HTTP, SSH..., des champs et paramètres passé dans la requête) ;
  - journalisation de l'activité

Le reverse-proxy

- Fonction : protéger des serveurs (web) exposés :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - Web Application Firewall (inspection des requêtes HTTP, SSH..., des champs et paramètres passé dans la requête) ;
  - journalisation de l'activité
  - terminaison SSL (gestion centralisée des secrets)

Le reverse-proxy

- Fonction : protéger des serveurs (web) exposés :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - Web Application Firewall (inspection des requêtes HTTP, SSH..., des champs et paramètres passé dans la requête) ;
  - journalisation de l'activité
  - terminaison SSL (gestion centralisée des secrets)
  - répartition de charge (serveurs backends)

Le reverse-proxy

- Fonction : protéger des serveurs (web) exposés :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - Web Application Firewall (inspection des requêtes HTTP, SSH..., des champs et paramètres passé dans la requête) ;
  - journalisation de l'activité
  - terminaison SSL (gestion centralisée des secrets)
  - répartition de charge (serveurs backends)
  - optimisation du trafic (services multi-localisés)

Le reverse-proxy

- Fonction : protéger des serveurs (web) exposés :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - Web Application Firewall (inspection des requêtes HTTP, SSH..., des champs et paramètres passé dans la requête) ;
  - journalisation de l'activité
  - terminaison SSL (gestion centralisée des secrets)
  - répartition de charge (serveurs backends)
  - optimisation du trafic (services multi-localisés)
- Contraintes d'utilisation :

Le reverse-proxy

- Fonction : protéger des serveurs (web) exposés :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - Web Application Firewall (inspection des requêtes HTTP, SSH..., des champs et paramètres passé dans la requête) ;
  - journalisation de l'activité
  - terminaison SSL (gestion centralisée des secrets)
  - répartition de charge (serveurs backends)
  - optimisation du trafic (services multi-localisés)
- Contraintes d'utilisation :
  - cf. parefeu

Le relai mail

- Fonction : maîtriser les échanges de mails :

Le relai mail

- Fonction : maîtriser les échanges de mails :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;

Le relai mail

- Fonction : maîtriser les échanges de mails :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - filtrage (inspection des requêtes SMTP, des corps de mails, des pièces jointes) ;

Le relai mail

- Fonction : maîtriser les échanges de mails :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - filtrage (inspection des requêtes SMTP, des corps de mails, des pièces jointes) ;
  - journalisation de l'activité

Le relai mail

- Fonction : maîtriser les échanges de mails :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - filtrage (inspection des requêtes SMTP, des corps de mails, des pièces jointes) ;
  - journalisation de l'activité
- Contraintes d'utilisation :

Le relai mail

- Fonction : maîtriser les échanges de mails :
  - rupture protocolaire des couches bases (les sessions TCP sont interprétées par le proxy, puis reconstruites vers leurs destination) ;
  - filtrage (inspection des requêtes SMTP, des corps de mails, des pièces jointes) ;
  - journalisation de l'activité
- Contraintes d'utilisation :
  - cf. parefeu

Plan

1 Introduction

2 Principes généraux d'architecture sécurisée

3 Socle de connaissances

4 Étude de cas : passerelle d'interconnexion à Internet

5 Conclusion

Plan

4 Étude de cas : passerelle d'interconnexion à Internet
- Expression de besoins
- Choix d'architecture
- Navigation Web
- Messagerie électronique
- Vision globale

Contexte métier

Postulats sur l'entité :

- elle a une offre de services comprenant la navigation Web et une messagerie électronique ;

Contexte métier

Postulats sur l'entité :

- elle a une offre de services comprenant la navigation Web et une messagerie électronique ;
- elle déploie et maintient préférentiellement ses propres infrastructures (pas ou peu de recours aux services *cloud*).

Contexte métier

Postulats sur l'entité :

- elle a une offre de services comprenant la navigation Web et une messagerie électronique ;
- elle déploie et maintient préférentiellement ses propres infrastructures (pas ou peu de recours aux services *cloud*).

Exemples de menaces :

- espionnage sur le service de messagerie électronique pour récupérer des données industrielles ou des accès plus privilégiés en vue d'une attaque plus persistante ;

Contexte métier

Postulats sur l'entité :

- elle a une offre de services comprenant la navigation Web et une messagerie électronique ;
- elle déploie et maintient préférentiellement ses propres infrastructures (pas ou peu de recours aux services *cloud*).

Exemples de menaces :

- espionnage sur le service de messagerie électronique pour récupérer des données industrielles ou des accès plus privilégiés en vue d'une attaque plus persistante ;
- attaque par rançongiciel faisant suite à une campagne d'hameçonnage visant l'entité et à la récupération d'une charge malveillante depuis le poste d'un utilisateur ;

Contexte métier

Postulats sur l'entité :

- elle a une offre de services comprenant la navigation Web et une messagerie électronique ;
- elle déploie et maintient préférentiellement ses propres infrastructures (pas ou peu de recours aux services *cloud*).

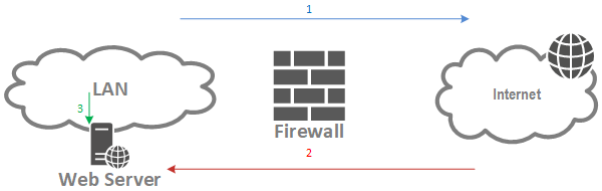
Exemples de menaces :

- espionnage sur le service de messagerie électronique pour récupérer des données industrielles ou des accès plus privilégiés en vue d'une attaque plus persistante ;
- attaque par rançongiciel faisant suite à une campagne d'hameçonnage visant l'entité et à la récupération d'une charge malveillante depuis le poste d'un utilisateur ;
- attaque par la chaîne d'approvisionnement (*supply chain*) en compromettant initialement l'accès distant du poste de travail d'un prestataire.

Plan

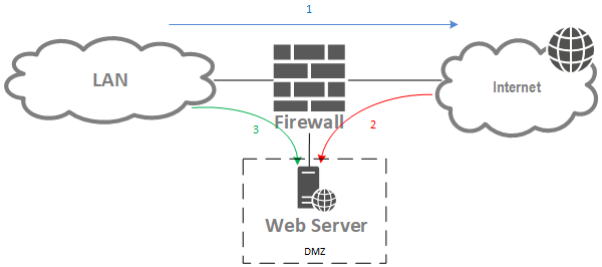
4 Étude de cas : passerelle d'interconnexion à Internet
- Expression de besoins
- Choix d'architecture
- Navigation Web
- Messagerie électronique
- Vision globale

architecture basique (chez soi, ou TPE)



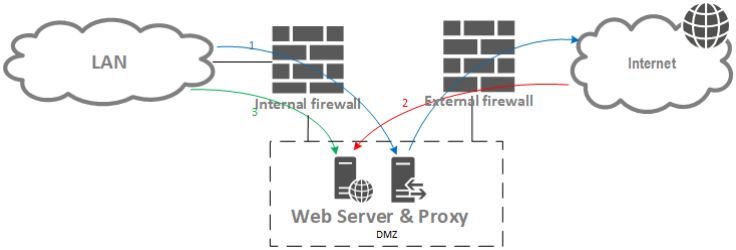
- (1) navigation depuis le LAN vers Internet ;
- (2) navigation depuis Internet vers un serveur web sur le LAN ;
- (3) navigation depuis le LAN vers un serveur web sur le LAN.

architecture à pare-feu unique



- la navigation locale est filtrée ;
- en cas de compromission du serveur web, l'attaquant ne gagne pas un accès direct au LAN.
- cependant, la moindre vulnérabilité ou mauvaise configuration sur le parefeu rend l'isolation inopérante.

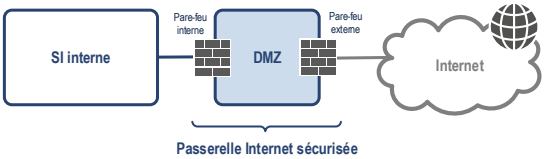
architecture à double pare-feu



- la compromission du pare-feu externe ne rend pas le LAN directement accessible ;
- la navigation externe bénéficie d'un filtrage ;

Mise en œuvre d'une DMZ

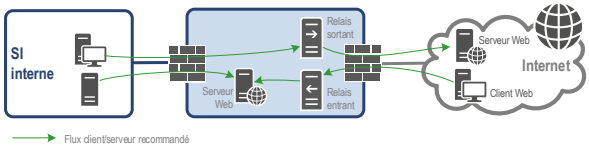
Objectif : disposer d'une **zone neutre et perdable**, protégée par des pare-feux périmétriques, et servant, en son sein et autant que possible, à la rupture protocolaire et à l'analyse du trafic échangé entre le SI interne de l'entité et Internet.



Cinématique des flux

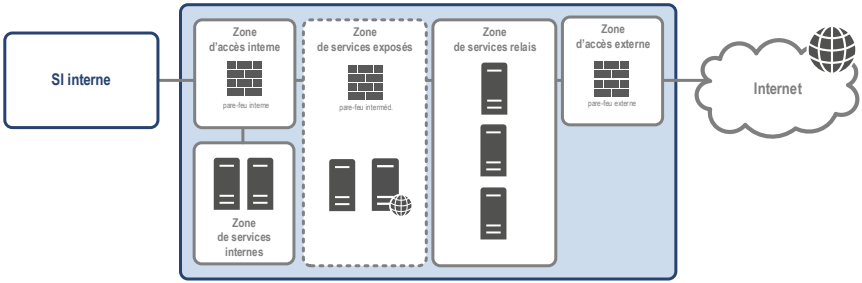
Doctrine de cinématique des flux

Les flux doivent être initialisés depuis la zone de plus haute confiance vers la zone de moindre confiance.

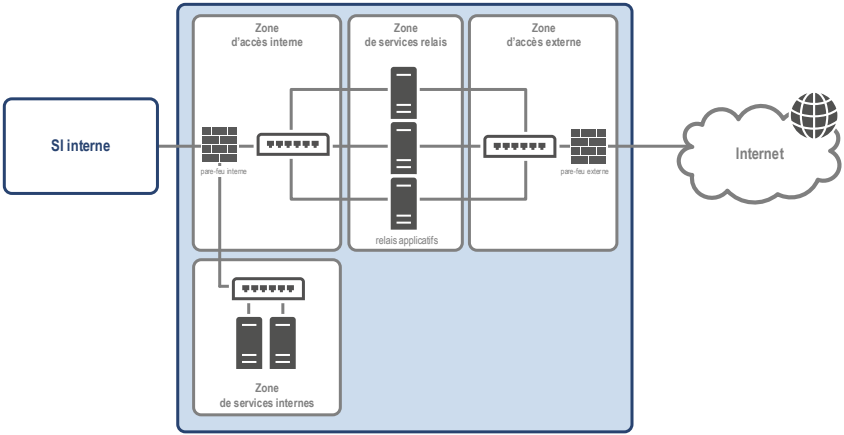


Segmentation de la DMZ

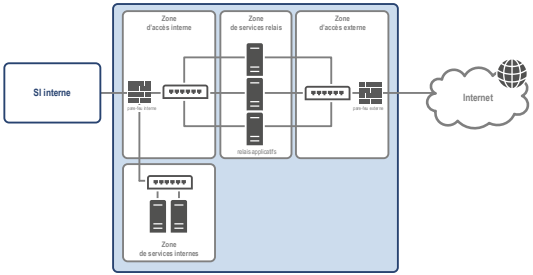
Segmentation en 4 ou 5 zones de confiance



Cloisonnement physique



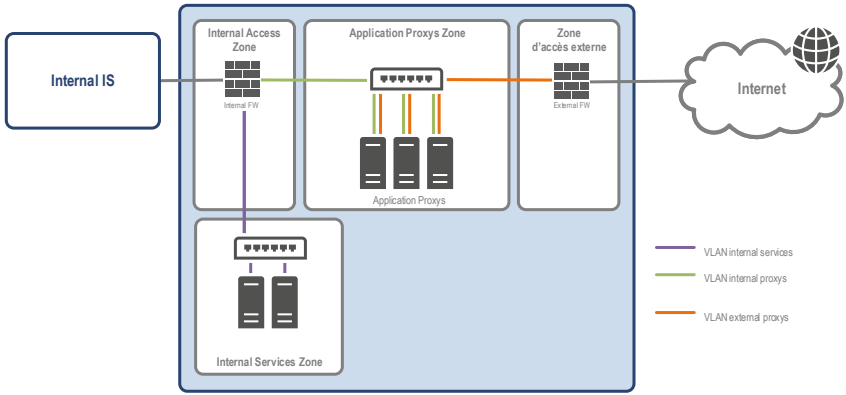
Cloisonnement physique



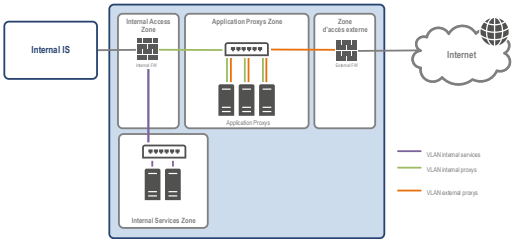
Ce cloisonnement physique :

- rend **incontournable** le passage par un relais applicatif ;
- limite les conséquences de l'exploitation d'une vulnérabilité d'un équipement réseau.

Cloisonnement logique



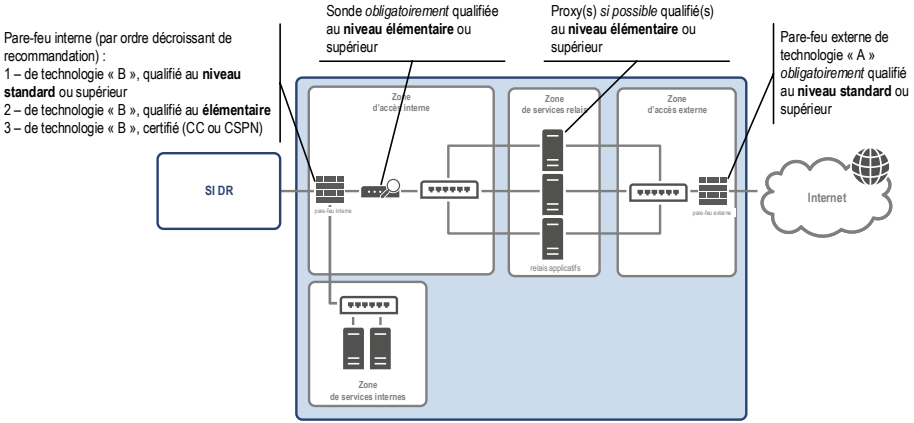
Cloisonnement logique



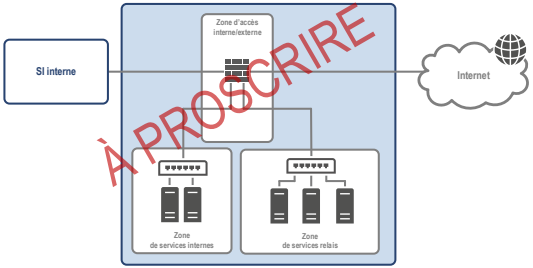
Ce cloisonnement logique :

- respecte certes la segmentation des zones de confiance…
- … mais repose sur les mécanismes de cloisonnement mis en œuvre par le commutateur …
- … et induit un trafic réseau « en trombone ».

Cas spécifique : passerelle de classe 1



Architecture à proscrire



L'exposition de l'unique pare-feu rend l'architecture extrêmement fragile : l'exploitation d'une vulnérabilité depuis Internet pourrait donner un accès direct au SI interne de l'entité.

Recommandations génériques

Administration sécurisée

Administrer de manière sécurisée la passerelle Internet sécurisée.

ANSSI-PA-022 Recommandations relatives à l'administration sécurisée des systèmes d'information

Recommandations génériques

Administration sécurisée

Administrer de manière sécurisée la passerelle Internet sécurisée.

ANSSI-PA-022 Recommandations relatives à l'administration sécurisée des systèmes d'information

Protection en disponibilité

- garantir la disponibilité attendue grâce à la résilience des accès opérateurs ;
- mettre en œuvre des contre-mesures aux attaques en déni de service.

Recommandations génériques

Administration sécurisée

Administrer de manière sécurisée la passerelle Internet sécurisée.

ANSSI-PA-022 Recommandations relatives à l'administration sécurisée des systèmes d'information

Protection en disponibilité

- garantir la disponibilité attendue grâce à la résilience des accès opérateurs ;
- mettre en œuvre des contre-mesures aux attaques en déni de service.

Protection en confidentialité

- ignorer les paquets refusés par la politique des pare-feux externes ;
- masquer l'architecture interne vis-à-vis d'Internet.

Plan

4 Étude de cas : passerelle d'interconnexion à Internet
- Expression de besoins
- Choix d'architecture
- Navigation Web
- Messagerie électronique
- Vision globale

Architecture du service de navigation Web

Besoins :

- **assurer une rupture protocolaire des flux vis-à-vis d'Internet** : mise en œuvre d'un **serveur mandataire** au sein de la zone de services relais ;

Architecture du service de navigation Web

Besoins :

- **assurer une rupture protocolaire des flux vis-à-vis d'Internet** : mise en œuvre d'un **serveur mandataire** au sein de la zone de services relais ;
- **authentifier les utilisateurs ou les services** : mise en œuvre d'une brique d'**authentification** au sein de la zone des services internes de la passerelle ;

Architecture du service de navigation Web

Besoins :

- **assurer une rupture protocolaire des flux vis-à-vis d'Internet** : mise en œuvre d'un **serveur mandataire** au sein de la zone de services relais ;
- **authentifier les utilisateurs ou les services** : mise en œuvre d'une brique d'**authentification** au sein de la zone des services internes de la passerelle ;
- **contrôler l'accès** aux sites Web : utilisation du serveur mandataire ;

Architecture du service de navigation Web

Besoins :

- **assurer une rupture protocolaire des flux vis-à-vis d'Internet** : mise en œuvre d'un **serveur mandataire** au sein de la zone de services relais ;
- **authentifier les utilisateurs ou les services** : mise en œuvre d'une brique d'**authentification** au sein de la zone des services internes de la passerelle ;
- **contrôler l'accès** aux sites Web : utilisation du serveur mandataire ;
- **tracer les accès** utilisateurs et administrateurs : mise en œuvre d'un collecteur de journaux dans le SI d'administration ;

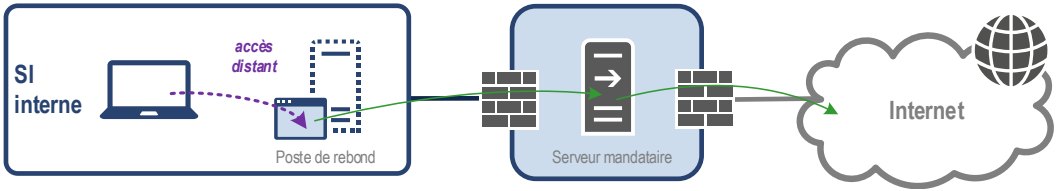
Architecture du service de navigation Web

Besoins :

- **assurer une rupture protocolaire des flux vis-à-vis d'Internet** : mise en œuvre d'un **serveur mandataire** au sein de la zone de services relais ;
- **authentifier les utilisateurs ou les services** : mise en œuvre d'une brique d'**authentification** au sein de la zone des services internes de la passerelle ;
- **contrôler l'accès** aux sites Web : utilisation du serveur mandataire ;
- **tracer les accès** utilisateurs et administrateurs : mise en œuvre d'un collecteur de journaux dans le SI d'administration ;
- **analyser les flux à la recherche de contenu malveillant** : étude de la mise en œuvre au niveau du serveur mandataire, notamment de l'inspection TLS pour les flux HTTPS.

Mise en œuvre de postes de rebond

Bonus pour les SI les plus sensibles !



Plan

4 Étude de cas : passerelle d'interconnexion à Internet
- Expression de besoins
- Choix d'architecture
- Navigation Web
- Messagerie électronique
- Vision globale

Étude des besoins du service de messagerie électronique

On distingue :

- **différents types** de messagerie électronique :

Étude des besoins du service de messagerie électronique

On distingue :

- **différents types** de messagerie électronique :
  - bureautique pour les utilisateurs ;

Étude des besoins du service de messagerie électronique

On distingue :

- **différents types** de messagerie électronique :
  - bureautique pour les utilisateurs ;
  - technique pour les équipes informatiques.

Étude des besoins du service de messagerie électronique

On distingue :

- **différents types** de messagerie électronique :
  - bureautique pour les utilisateurs ;
  - technique pour les équipes informatiques.
- **différents niveaux d'exposition** :

Étude des besoins du service de messagerie électronique

On distingue :

- **différents types** de messagerie électronique :
  - bureautique pour les utilisateurs ;
  - technique pour les équipes informatiques.
- **différents niveaux d'exposition** :
  - à Internet ;

Étude des besoins du service de messagerie électronique

On distingue :

- **différents types** de messagerie électronique :
  - bureautique pour les utilisateurs ;
  - technique pour les équipes informatiques.
- **différents niveaux d'exposition** :
  - à Internet ;
  - strictement en interne.

Étude des besoins du service de messagerie électronique

On distingue :

- **différents types** de messagerie électronique :
  - bureautique pour les utilisateurs ;
  - technique pour les équipes informatiques.
- **différents niveaux d'exposition** :
  - à Internet ;
  - strictement en interne.
- potentiellement **différents niveaux de sensibilité**.

Étude des besoins du service de messagerie électronique

On distingue :

- **différents types** de messagerie électronique :
  - bureautique pour les utilisateurs ;
  - technique pour les équipes informatiques.
- **différents niveaux d'exposition** :
  - à Internet ;
  - strictement en interne.
- potentiellement **différents niveaux de sensibilité**.

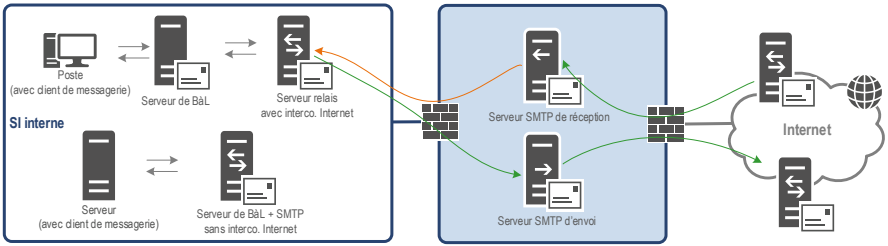
Migration de la messagerie électronique « dans les nuages »

Migrer un service de messagerie électronique dans le *cloud* nécessite une bonne analyse de risques, notamment portant sur la confidentialité des données et la réversibilité.

Architecture du service de messagerie électronique

Principes

- les serveurs de boîtes aux lettres sont hébergés dans le SI interne ;
- les serveurs relais de réception et d'envoi (SMTP) sont cloisonnés et déployés en fonction des stricts besoins ;
- **pas d'exposition de Webmail sur Internet.**



Fonctions de sécurité

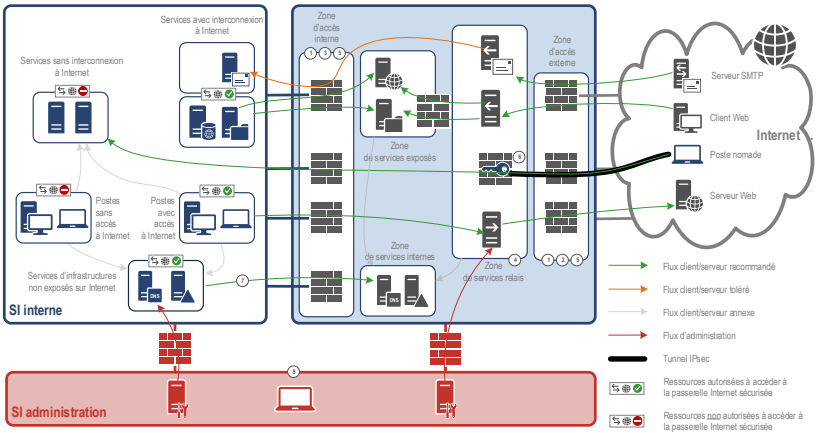
Pour couvrir les différentes menaces liées à la messagerie électronique (ex. : espionnage, usurpation d'identité à des fins d'hameçonnage), il est recommandé :

- l'activation du **chiffrement sur le transport** (STARTTLS configuré sur les serveurs relais, accès HTTPS pour les clients) indépendamment du chiffrement des courriels ;
- la configuration de **mécanismes antispam** : liste d'autorisation, d'interdiction, analyse heuristique, test de Turing ;
- l'**analyse de contenu** à la recherche de codes malveillants : analyse antivirus, filtrage par extension, etc. ;
- la **configuration des protocoles SPF, DKIM et DMARC** pour renforcer la légitimité des courriels reçus et envoyés.

Plan

4 Étude de cas : passerelle d'interconnexion à Internet
- Expression de besoins
- Choix d'architecture
- Navigation Web
- Messagerie électronique
- Vision globale

Architecture globale



Plan

1 Introduction

2 Principes généraux d'architecture sécurisée

3 Socle de connaissances

4 Étude de cas : passerelle d'interconnexion à Internet

5 Conclusion

À retenir

Principes d'architecture sécurisée, avant la mise en œuvre d'une *blockchain*, d'une solution connectée à une IA ou d'un équipement auto-apprenant par ML :

- segmenter les SI en zones de confiance ;

À retenir

Principes d'architecture sécurisée, avant la mise en œuvre d'une *blockchain*, d'une solution connectée à une IA ou d'un équipement auto-apprenant par ML :

- segmenter les SI en zones de confiance ;
- cloisonner ces zones de confiance pour limiter les risques et les conséquences d'une compromission ;

À retenir

Principes d'architecture sécurisée, avant la mise en œuvre d'une *blockchain*, d'une solution connectée à une IA ou d'un équipement auto-apprenant par ML :

- segmenter les SI en zones de confiance ;
- cloisonner ces zones de confiance pour limiter les risques et les conséquences d'une compromission ;
- diversifier les technologies dans les limites permises par la maintenabilité du parc ;

À retenir

Principes d'architecture sécurisée, avant la mise en œuvre d'une *blockchain*, d'une solution connectée à une IA ou d'un équipement auto-apprenant par ML :

- segmenter les SI en zones de confiance ;
- cloisonner ces zones de confiance pour limiter les risques et les conséquences d'une compromission ;
- diversifier les technologies dans les limites permises par la maintenabilité du parc ;
- administrer de manière sécurisée ;

À retenir

Principes d'architecture sécurisée, avant la mise en œuvre d'une *blockchain*, d'une solution connectée à une IA ou d'un équipement auto-apprenant par ML :

- segmenter les SI en zones de confiance ;
- cloisonner ces zones de confiance pour limiter les risques et les conséquences d'une compromission ;
- diversifier les technologies dans les limites permises par la maintenabilité du parc ;
- administrer de manière sécurisée ;
- collecter les journaux d'événements et mettre en œuvre une supervision de sécurité ;

À retenir

Principes d'architecture sécurisée, avant la mise en œuvre d'une *blockchain*, d'une solution connectée à une IA ou d'un équipement auto-apprenant par ML :

- segmenter les SI en zones de confiance ;
- cloisonner ces zones de confiance pour limiter les risques et les conséquences d'une compromission ;
- diversifier les technologies dans les limites permises par la maintenabilité du parc ;
- administrer de manière sécurisée ;
- collecter les journaux d'événements et mettre en œuvre une supervision de sécurité ;
- ne pas négliger les outils et la politique de sauvegarde.

Références bibliographiques ANSSI

Guides ANSSI à destination des architectes SI :

ANSSI-PA-022 Recommandations relatives à l'administration sécurisée des systèmes d'information

ANSSI-PA-044 Recommandations pour choisir des pare-feux maîtrisés dans les zones exposées à Internet

ANSSI-PA-054 Recommandations sur le nomadisme numérique

ANSSI-PA-066 Recommandations relatives à l'interconnexion d'un système d'information à Internet

ANSSI-PA-072 Recommandations sur la sécurisation des systèmes de contrôle d'accès physique et de vidéoprotection

ANSSI-PG-075 Recommandations pour les architectures des systèmes d'information sensibles ou diffusion restreinte

ANSSI-PA-085 Recommandations pour la protection des systèmes d'information essentiels

L'ANSSI recrute



Stages, contrats d'apprentissage, CDD...

...Rendez-vous sur **https ://www.welcometothejungle.com/fr/companies/anssi**

Questions : cyril.poirret (at) ssi.gouv.fr